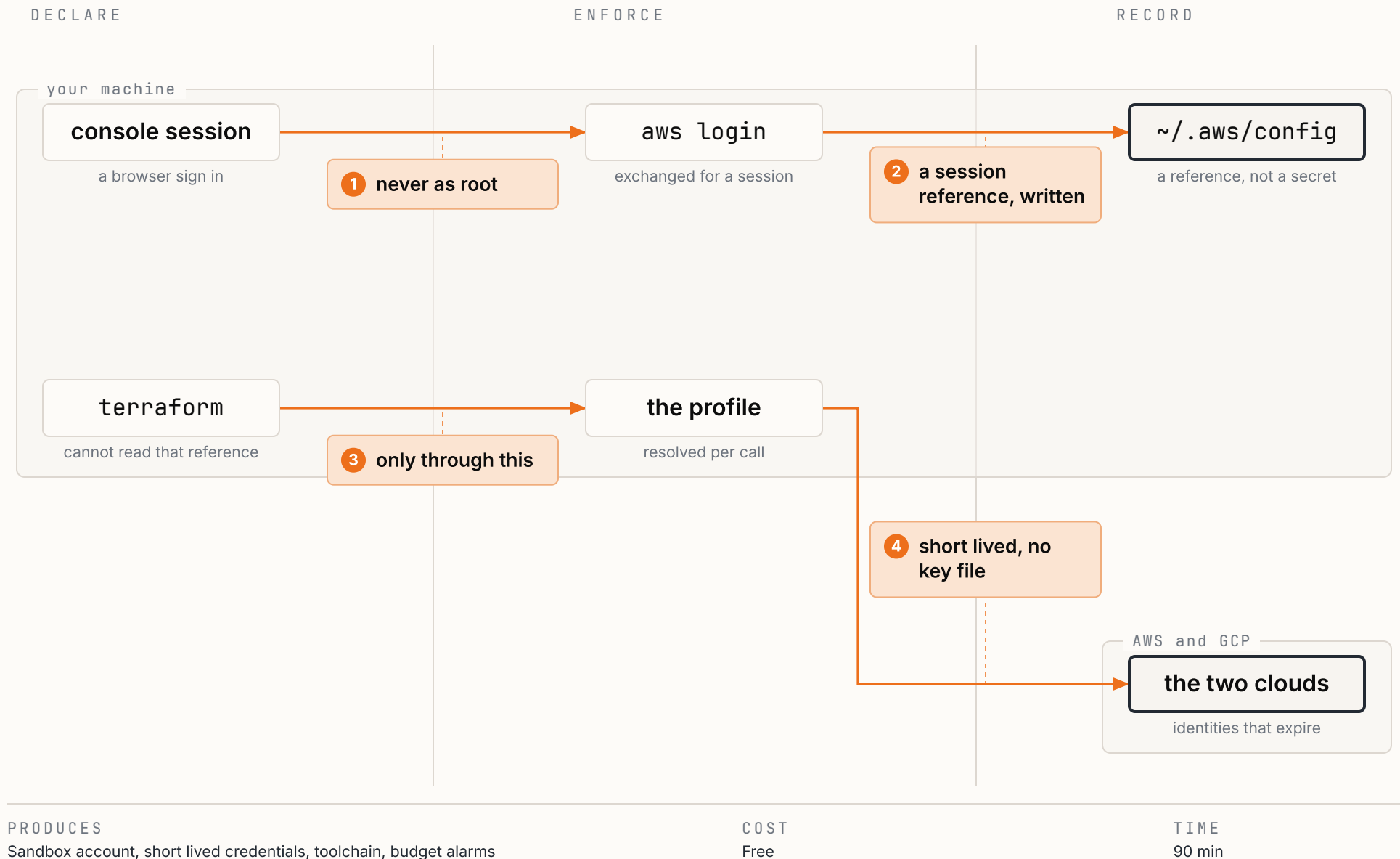


0.1 Prerequisites and Credentials AWS + GCP

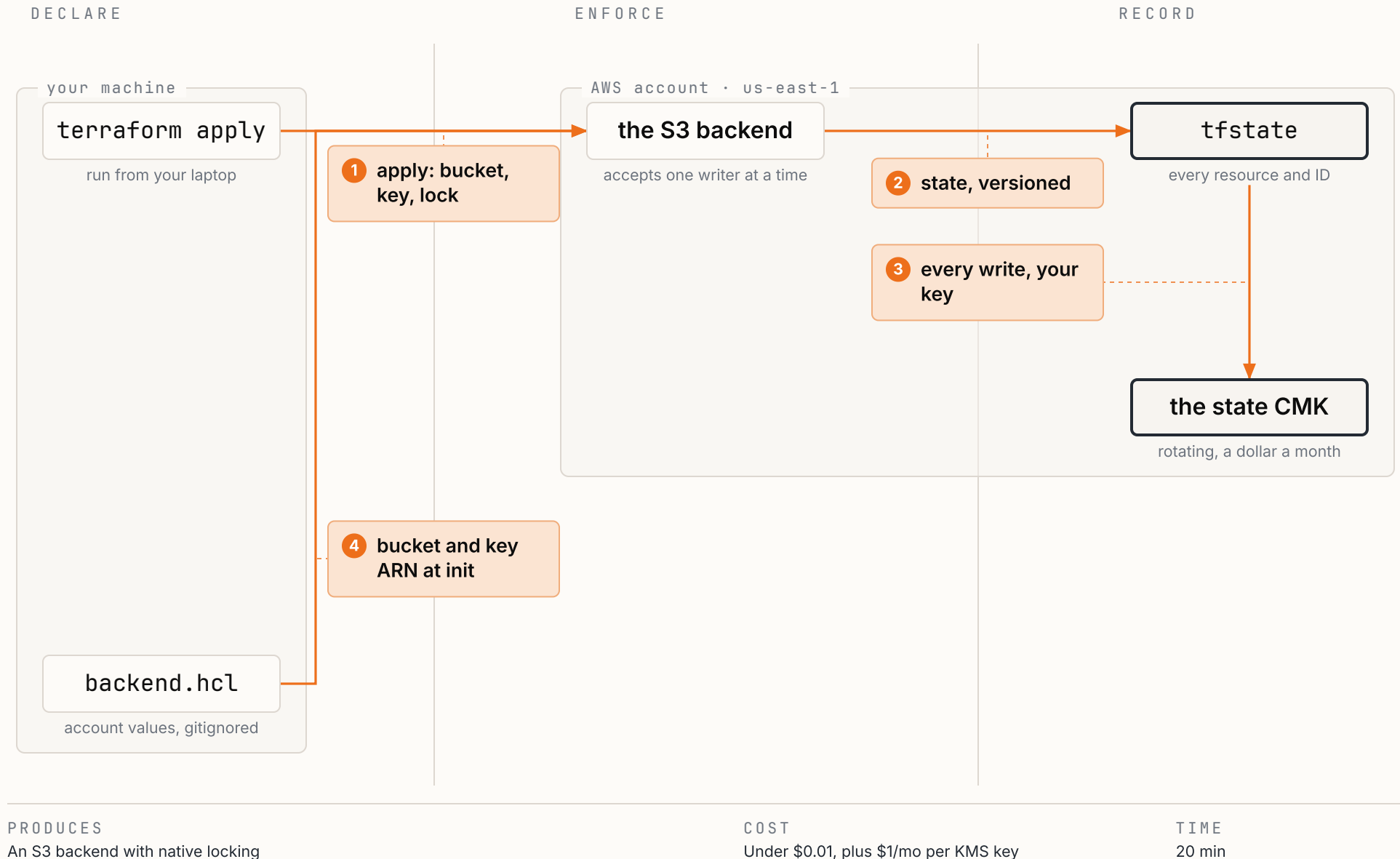
Nothing is deployed. You establish an identity in both clouds that expires on its own, and cap what everything after it can cost.



Terraform reaches the session only through a credential_process profile. Set the budget alarm before the first apply.

2.2 Remote State Backend AWS

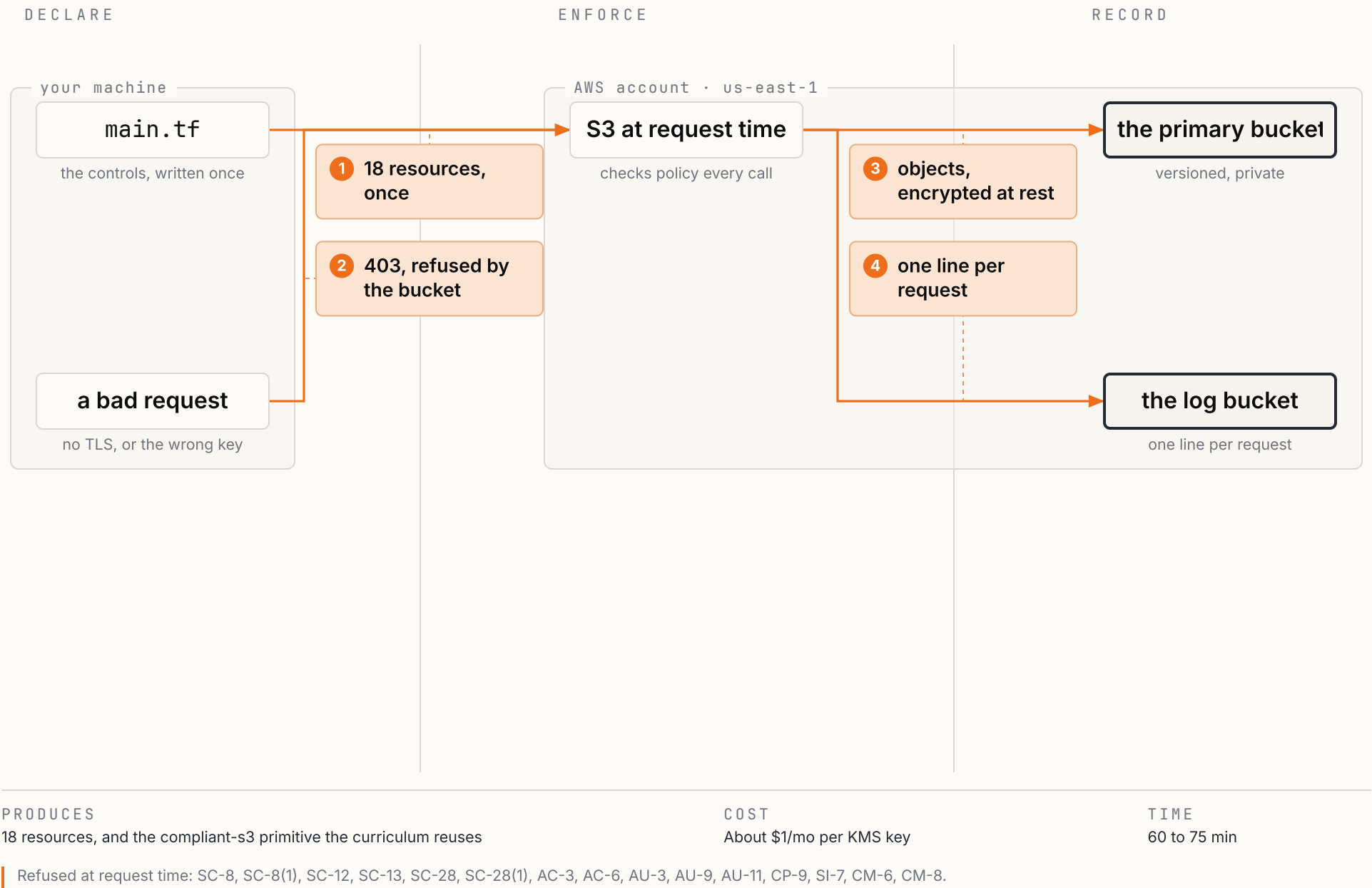
Terraform's record of what it built moves off your laptop. Without shared state a fresh runner plans against nothing and offers to build everything twice.



Chapter 4's pipeline is only completable because this exists. State is plaintext to whoever can decrypt it.

2.3 First Compliant Resource AWS

You describe the controls once as Terraform. AWS then enforces them on every request that follows, with you nowhere in the loop.



PRODUCES

18 resources, and the compliant-s3 primitive the curriculum reuses

COST

About \$1/mo per KMS key

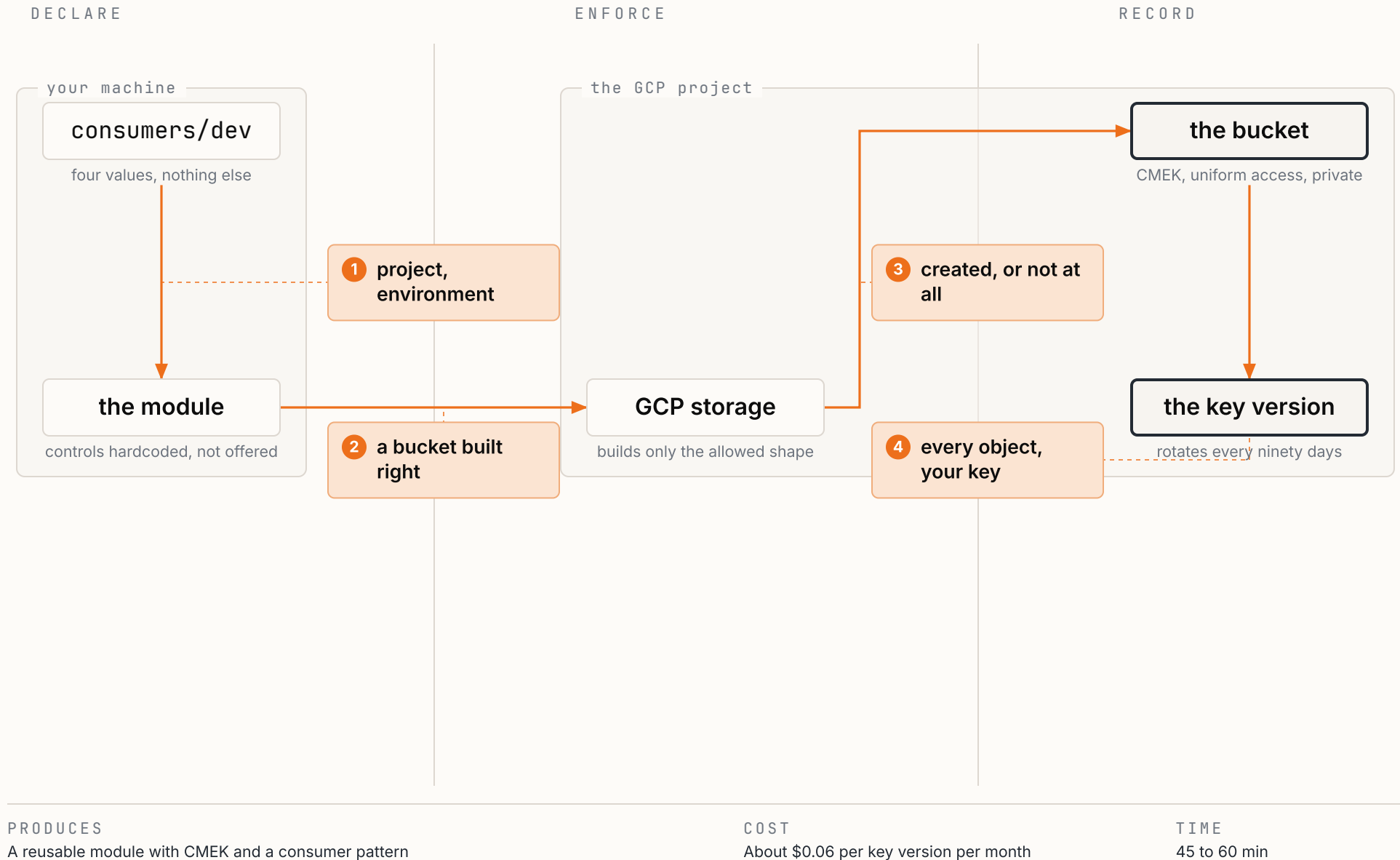
TIME

60 to 75 min

Refused at request time: SC-8, SC-8(1), SC-12, SC-13, SC-28, SC-28(1), AC-3, AC-6, AU-3, AU-9, AU-11, CP-9, SI-7, CM-6, CM-8.

2.4 Modules for Compliance GCP

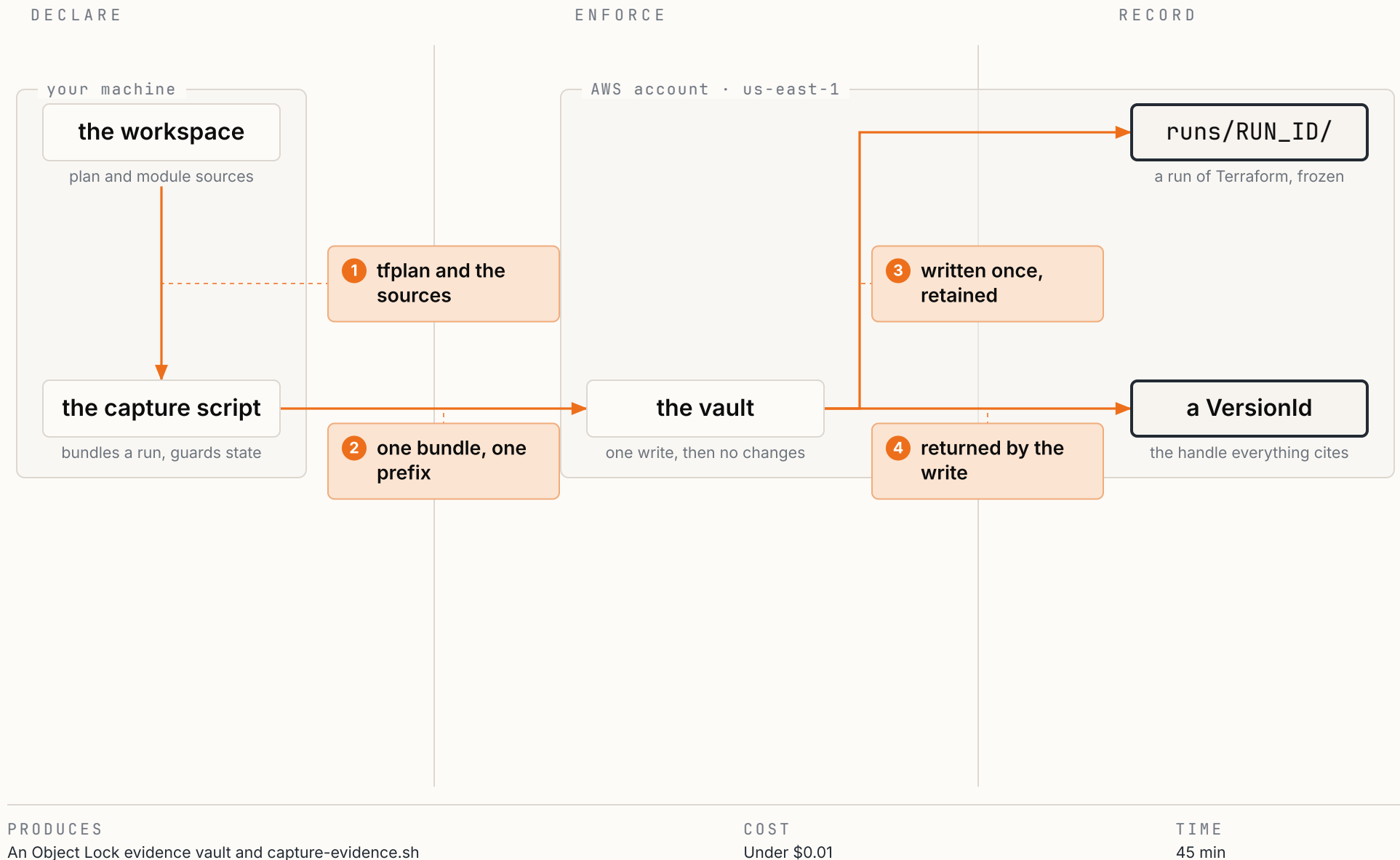
A module turns a set of decisions into a default that every consumer inherits, so the argument happens once instead of in every review.



What a team cannot configure, it cannot misconfigure. The module returns a computed attestation.

2.5 IaC as Compliance Evidence AWS

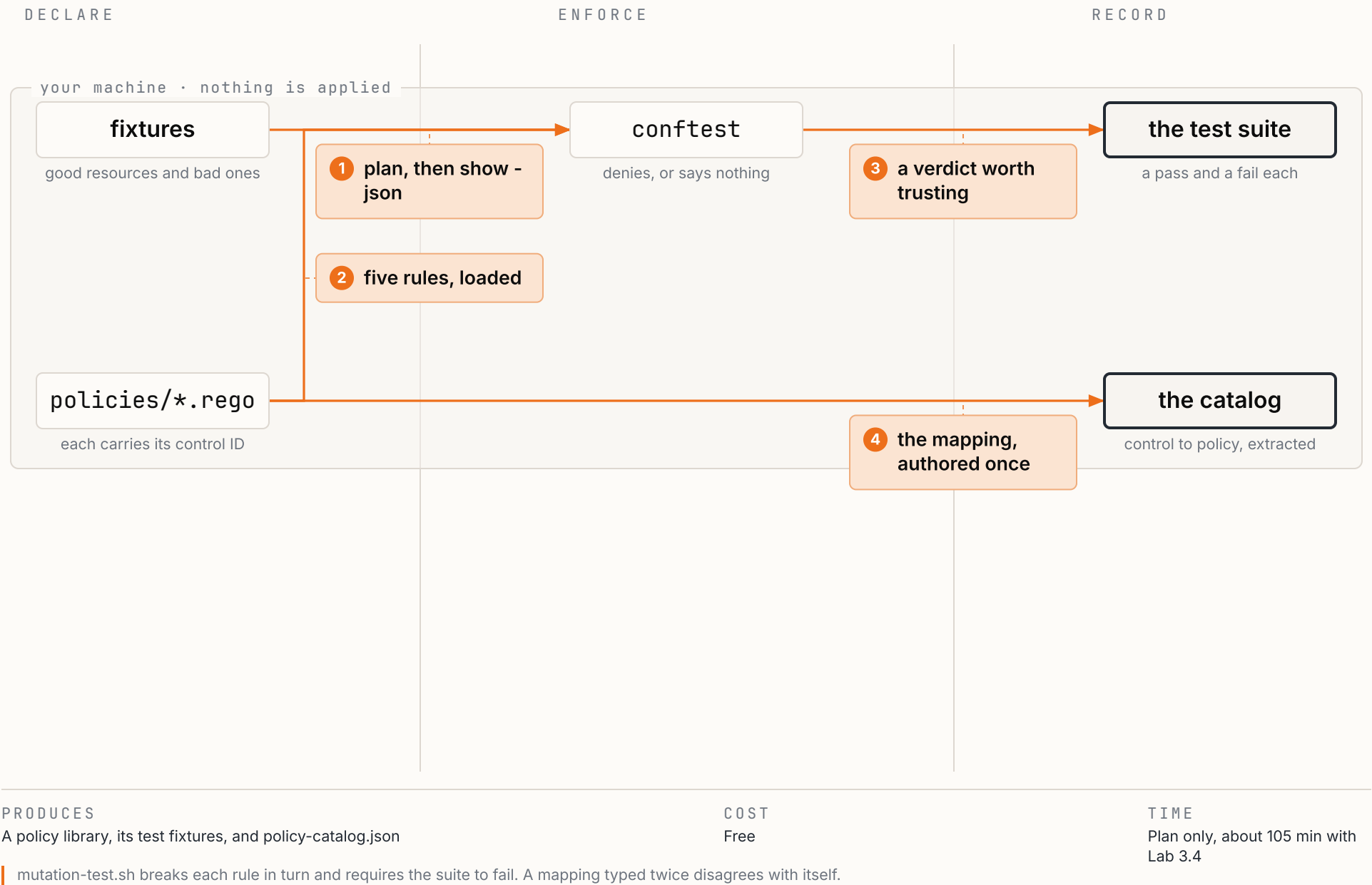
Evidence you can delete is not evidence. Object Lock makes a run permanent, which cuts both ways: a captured secret becomes undeletable too.



Think before you capture. Immutable means immutable, including a secret you did not mean to include.

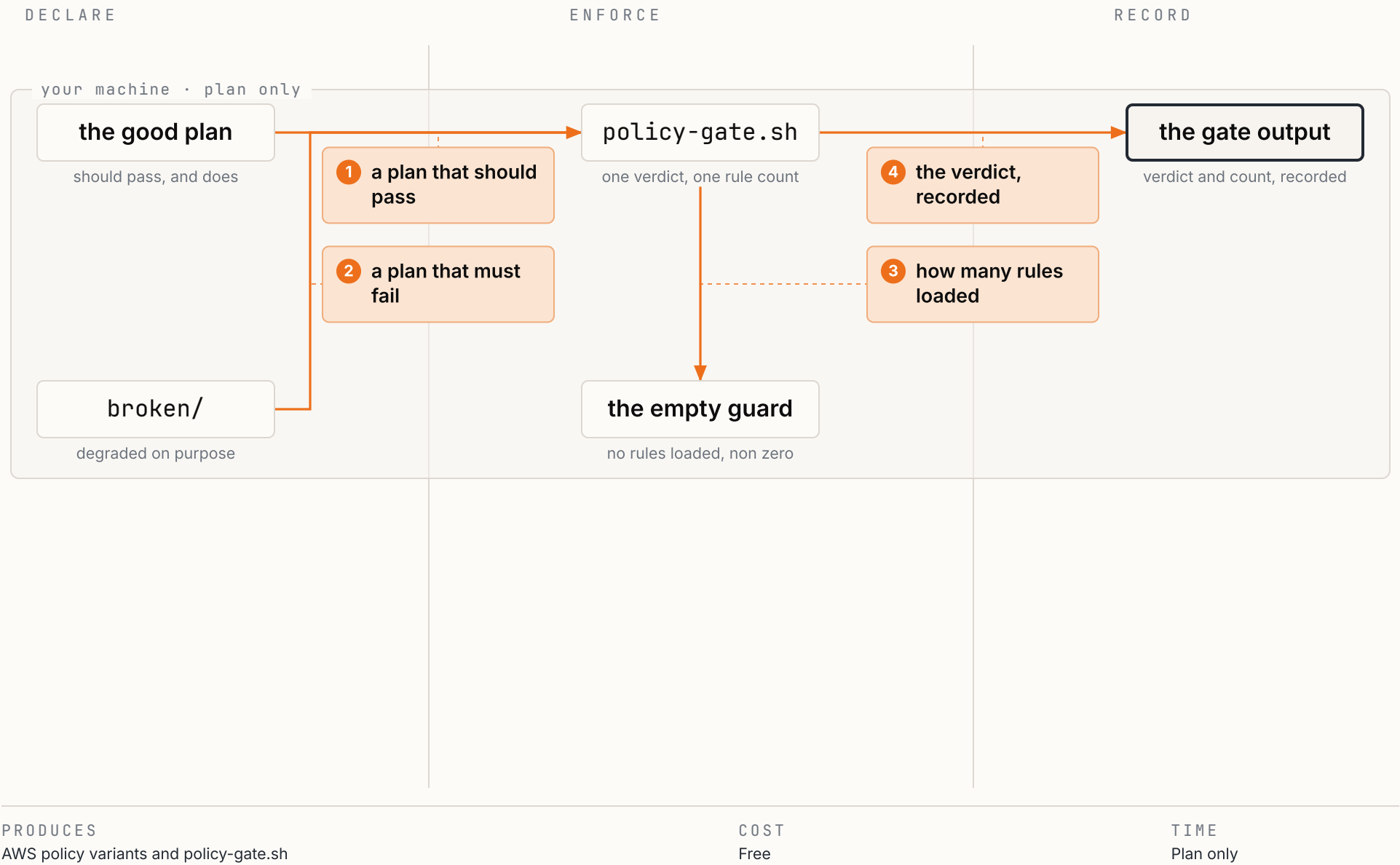
3.3 Writing Rego GCP

A policy no test constrains cannot fail, so this lab breaks every rule on purpose and requires the tests to notice.



3.4 Conftest and Terraform AWS

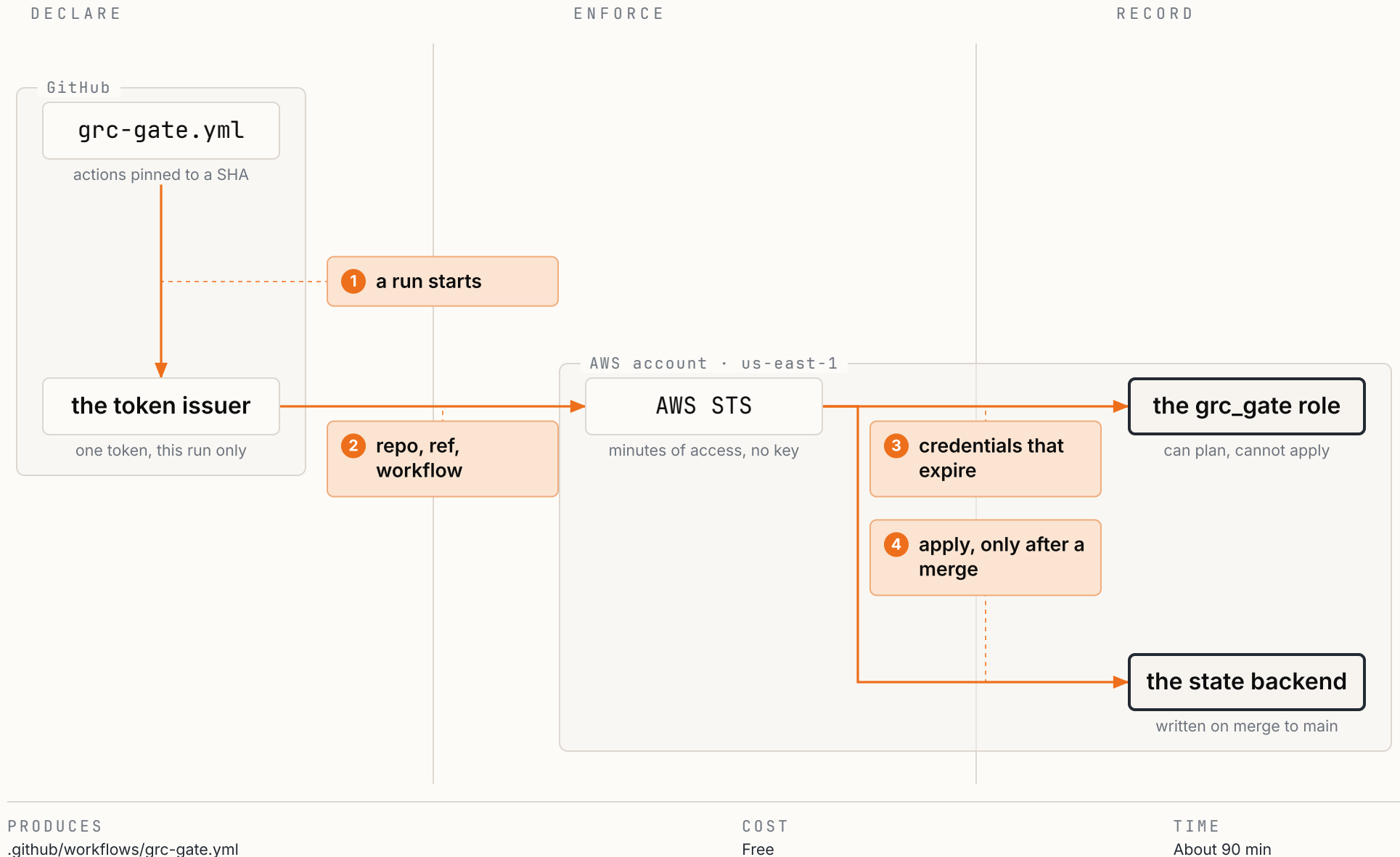
The gate runs against a Terraform plan, so a violation is caught before anything exists rather than found after it already does.



CI shells out to this script rather than reimplementing it, so what runs there is what ran here.

4.3 GRC Evidence Pipeline AWS

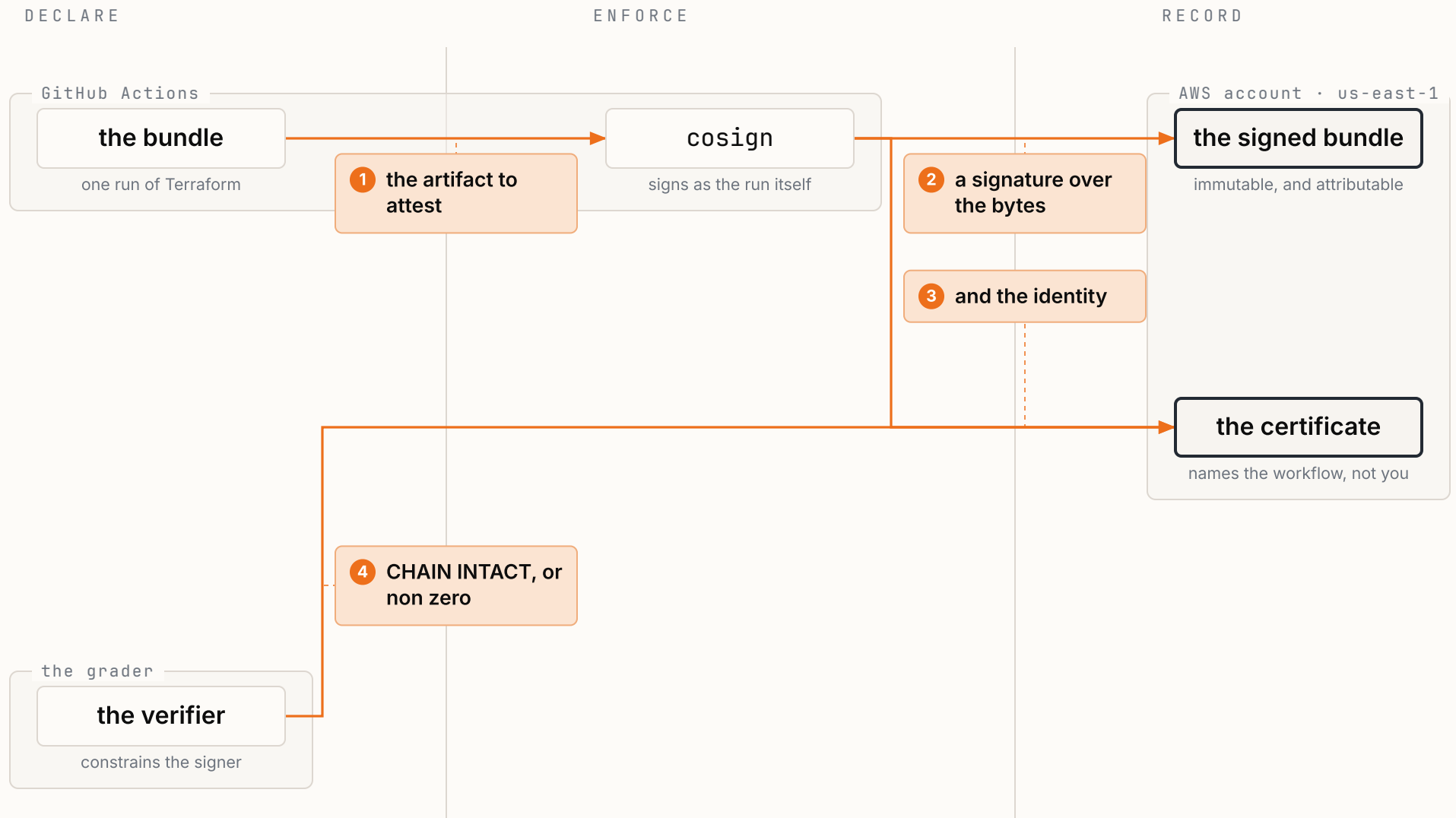
The checks a human ran by hand become the thing that must pass before a merge.



A compromised workflow reads your infrastructure and stops there, because the role cannot apply.

4.4 Chain of Custody AWS

A signature answers who produced an artifact and whether it changed. Verification has to constrain the signer, or it answers neither.



PRODUCES

Cosign signing wired into the vault

COST

Free

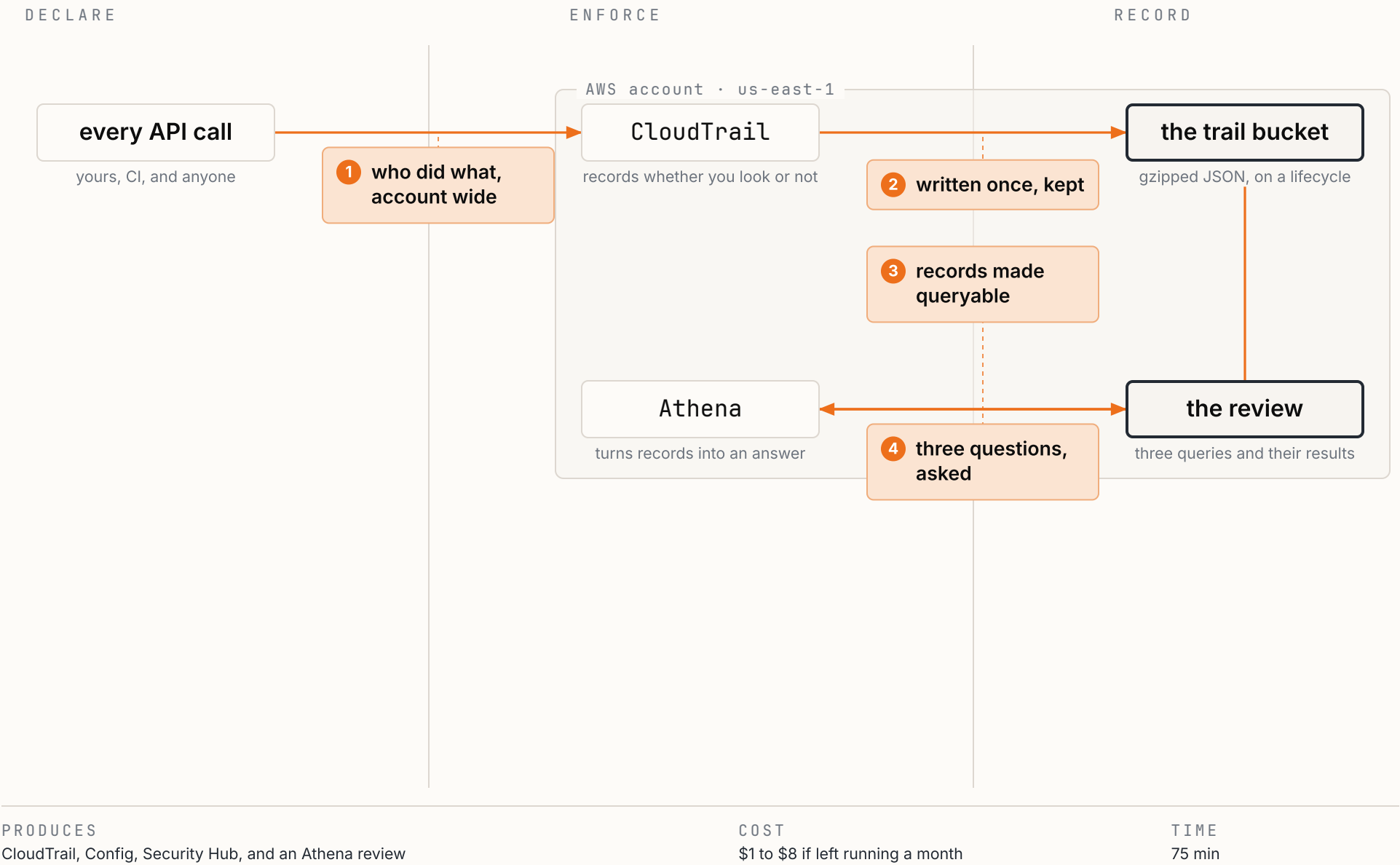
TIME

About 60 min

verify-evidence.sh constrains the signer. A script that accepts any valid signature verifies nothing.

5.2 AWS Security Services AWS

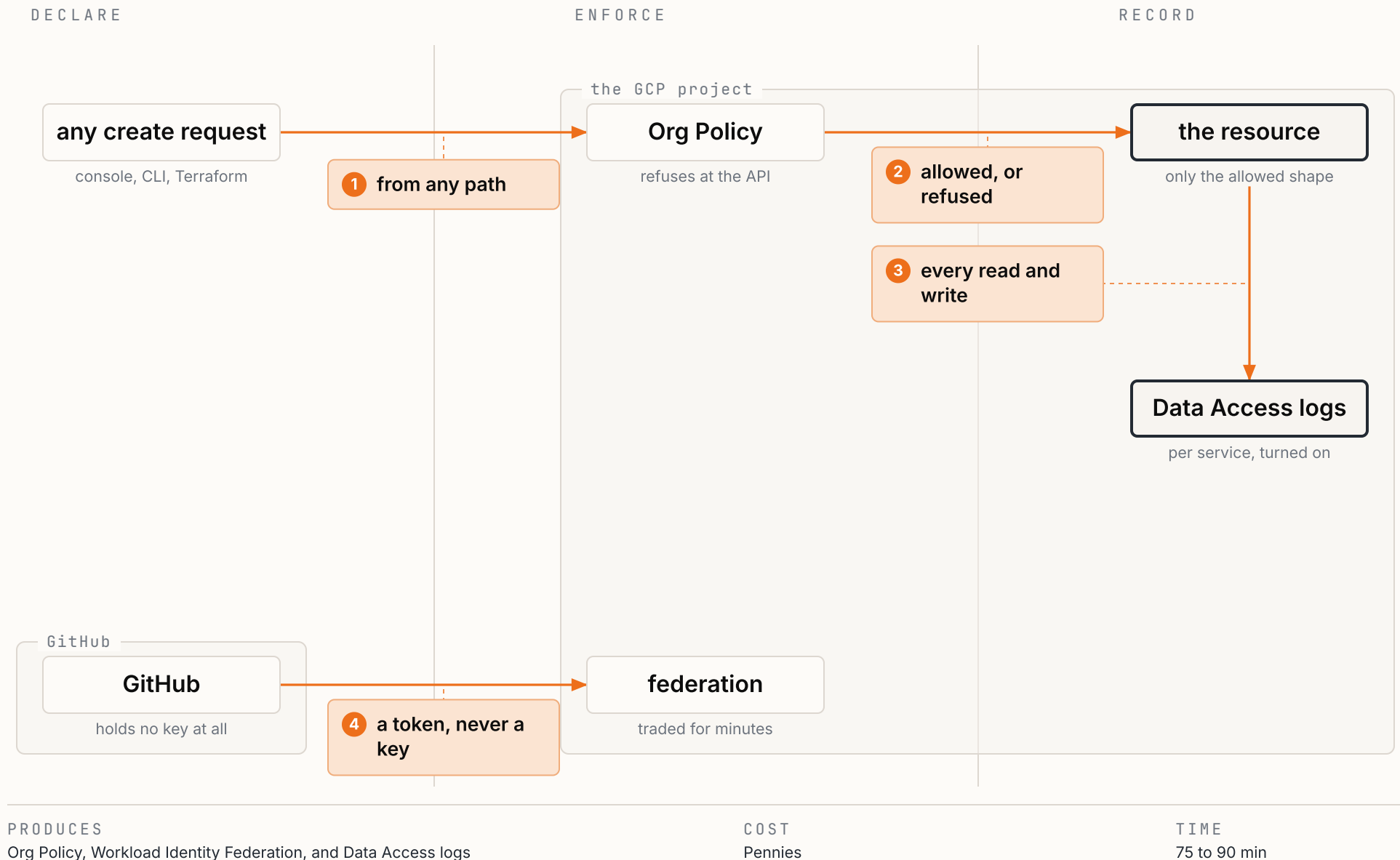
Collecting logs is AU-3 and AU-11. Actually reading them is AU-6, and that costs a query engine.



Data events are scoped to the vault, because they bill per event. Also here: AU-2, AU-10, AU-12, SI-4, RA-5, CM-2.

5.4 GCP Security Services GCP

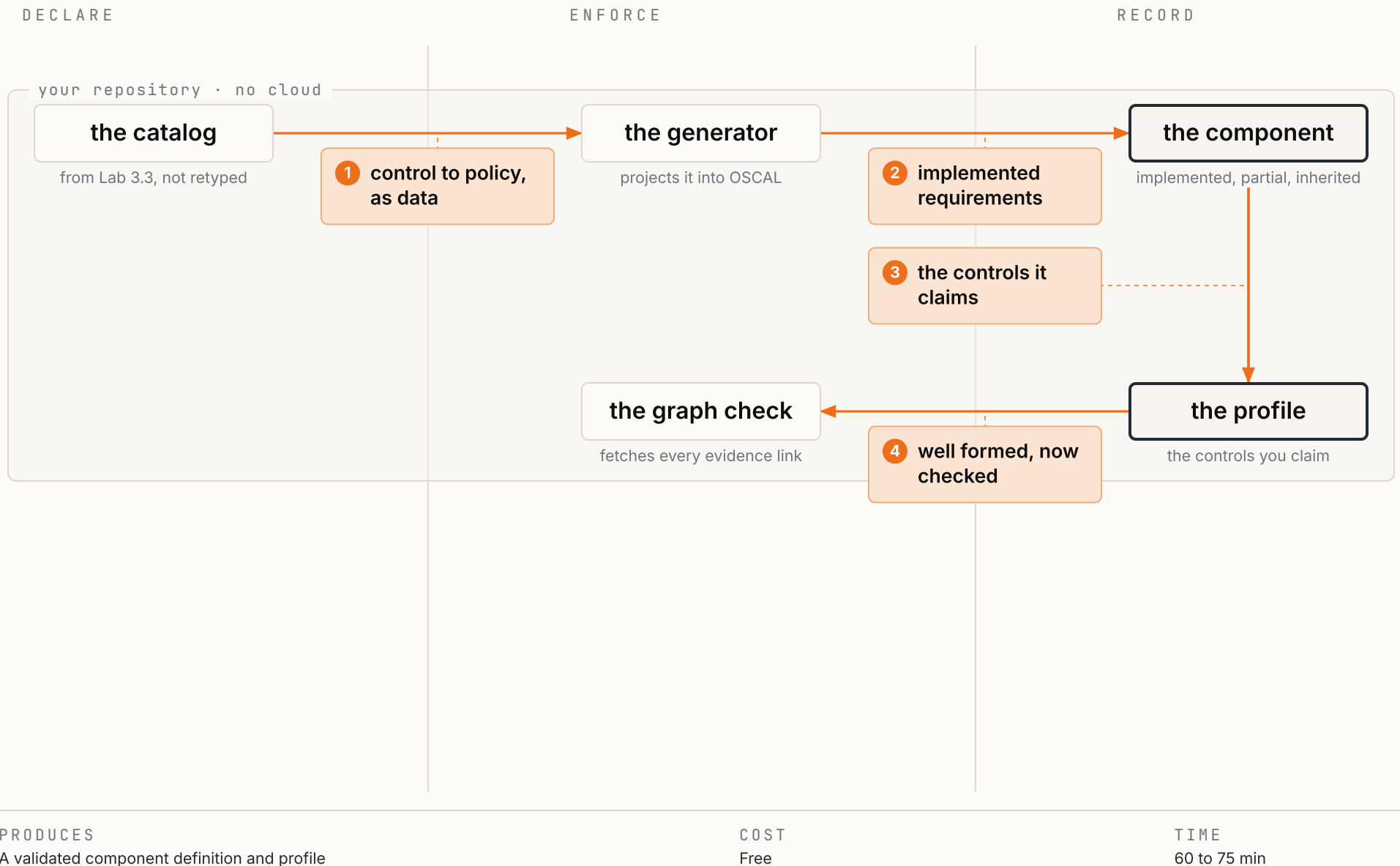
An org policy stops the action at the API for everyone, including someone clicking in the console. That is stronger than a module standard.



There is no drift to detect, because there is no drift. What the platform provides, record as inherited.

6.1 Introduction to OSCAL NO CLOUD

The control narrative becomes a machine readable artifact a tool can validate, instead of a document a human rereads and hopes is current.



| trestle proves the document is well formed. Only verify-oscal-graph.sh proves it describes anything real.